Université Cheikh Ahmadoul Khadim – UCAK de Touba

PROJET DE MÉMOIRE

Conception et mise en place d'un système de gestion des vulnérabilités pour l'Université Cheikh Ahmadoul Khadim

LIVRABLE — SEMAINE 1 / 6 DU CHRONOGRAMME

Note de synthèse méthodologique (Objectif 1)
Comparaison des scanners de vulnérabilités (Objectif 2)

Réalisé par **: Makane Seck**

Encadrant : Dr. Abdoul Aziz Ciss

1. Objet du livrable

Ce document constitue le livrable attendu à l'issue de la **semaine 1** du chronogramme du projet de mémoire. Il se limite strictement aux deux objectifs de cette semaine :

- **Objectif 1 :** note de synthèse méthodologique sur le cycle de vie de la gestion des vulnérabilités (identification → évaluation → remédiation → vérification) ;
- **Objectif 2 :** analyse comparative des scanners de vulnérabilités (OpenVAS, Nessus, Qualys) et justification du choix retenu : **OpenVAS**

Semaine	Objectifs	Activités clés	Livrable attendu	Statut
1	**Obj. 1 :** Cycle de vie de la GdV **Obj. 2 :** Comparaison des scanners	Recherche documentaire sur les phases identification / évaluation / remédiation / vérification. Analyse comparative des scanners opensource et commerciaux (fonctionnalités, coût, couverture).	Note de synthèse méthodologique + tableau comparatif des scanners	**FAIT (ce document)**

2. Objectif 1 — Étude du cycle de vie de la gestion des vulnérabilités

2.1 Définitions et cadre

- **Vulnérabilité :** faiblesse dans la conception, la configuration ou l'implémentation d'un actif, exploitable par une menace. Référencée par **CVE** (vulnérabilité) et **CWE** (classe de faiblesse).
- **Risque :** (vulnérabilité, menace, exposition, valeur de l'actif). Une vulnérabilité de même score CVSS sur un poste isolé et sur un serveur exposé ne génèrent pas le même risque.
- **Gestion des vulnérabilités (GdV) :** processus continu, articulant trois piliers : **processus** (les 4 phases ci-dessous), **acteurs** (responsables, SLA) et **outils** (scanner, ticketing, reporting).

La GdV ne se réduit pas au « scan » : sa valeur est d'**identifier, mesurer et réduire en continu la dette de sécurité** de l'infrastructure, en la traitant **par ordre de priorité** et en laissant une traçabilité.

2.2 Les quatre phases du cycle

Phase 1 : Identification

Détecter les vulnérabilités de l'infrastructure **avant leur exploitation** par un attaquant.

Élément	Description
Objectif	Détecter les vulnérabilités de l'infrastructure avant qu'elles ne soient exploitées.

Activités clés	**(a)** inventaire exhaustif des actifs (SI, équipements réseau, cloud, IoT) — prérequis absolu; **(b)** scans non authentifiés (ports, services, versions, CVE connues) ; **(c)** scans authentifiés (Windows WinRM/SMB, Linux SSH, Cisco SNMP/SSH → patches, comptes, configuration) ; **(d)** audit de configuration des équipements réseau et du cloud.
Entrées → sorties	Inventaire + credentials + périmètre → inventaire vérifié + liste brute de vulnérabilités
Outils	Nmap, scanner OpenVAS (GVM), audit de configuration (SNMP/SSH)

Phase 2 : Évaluation (quantification et priorisation)

Élément	Description
Objectif	Distinguer ce qui doit être corrigé en premier : du score technique à la décision métier.
Activités clés	**(a)** scoring CVSS 3.1 : vecteur, score de base 0–10 (Critique ≥ 9,0), ajustements temporels et environnementaux ; **(b)** complément exploitabilité : EPSS (probabilité empirique d'exploitation) ; **(c)** contextualisation métier : criticité de l'actif et des données, exposition (interne / publique), contrôles compensatoires existants, contraintes réglementaires ; **(d)** décision par vulnérabilité : traiter / accepter (justifiée) / atténuer / transférer.
Entrées → sorties	Liste brute → registre de risques + liste priorisée
Outils	Calculateur CVSS, plateforme GdV (OpenVAS), matrice de risques

Phase 3 : Remédiation

Élément	Description
Objectif	Corriger les risques acceptés au moindre impact métier, de façon traçable.

Activités clés	Actions de correction : patchs, durcissement de configuration, mesures compensatoires (VPN/IPSec, segmentation, WAF), remplacement/migration des équipements EOL. Workflow : ticket par vulnérabilité → responsable désigné → délai par sévérité (SLA / MTTM) → suivi des états (à corriger / en cours / corrigé / accepté).
Entrées → sorties	Liste priorisée → plan de remédiation, actions exécutées, registre mis à jour (risques acceptés documentés)
Outils	Gestion de tickets (GLPI/Jira), procédures de patching, plateforme GdV

Phase 4 : Vérification et amélioration continue

Élément	Description
Objectif	Prouver que les corrections ont pris effet et entretenir le processus dans le temps.
Activités clés	**(a)** re-scan des actifs remédiés (tests de nonrégression) ; **(b)** validation de la clôture des vulnérabilités; **(c)** détection continue (nouveaux CVE, nouveaux actifs, évolutions du parc) ; **(d)** mesure des KPI : couverture (actifs scannés / total), MTTD, MTTM, % critiques dans les délais, tendance ; **(e)** reporting périodique à la direction + traçabilité d'audit.
Entrées → sorties	Actions remédiées → rapports de vérification, tableau de bord KPI, boucle d'amélioration (PDCA)
Outils	Scans planifiés (GVM), exports PDF, tableau de bord KPI

2.3 Un cycle continu, ancré dans les référentiels

Les quatre phases forment une boucle PDCA : l'apparition hebdomadaire de nouveaux CVE et l'évolution du parc (nouveaux équipements, migration) rendent le cycle **permanent**, et non ponctuel.

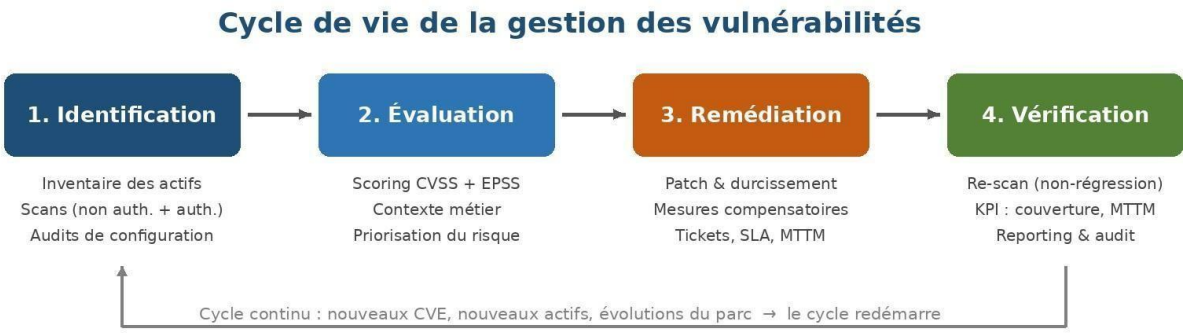


Figure 1 — Cycle de vie de la GdV (identification → évaluation → remédiation → vérification).

La démarche s'inscrit dans les bonnes pratiques reconnues :

Référentiel	Exigence correspondante
ISO/IEC 27001 (2022)	A.8.8 « Gestion des faiblesses et vulnérabilités techniques »
NIST SP 800-40 r5	Processus de gestion des correctifs de sécurité (patch management)
NIST SP 800-53	RA-5 « Scan et correction des vulnérabilités »
CIS Controls v8	8.5 « Gestion des vulnérabilités logicielles » (inventaire + scan + remédiation)
PCI DSS v4.0	11.3 / 11.4 — gestion des vulnérabilités et scans techniques réguliers

2.4 Appliquer la méthodologie à notre contexte

La note de synthèse n'est pas purement académique : chaque phase est déjà « câblée » sur le contexte réel étudié (UCAK de Touba : datacenter au Rectorat, double liaison FO Sonatel MADIYANA / NDAM MBACKÉ, 8 sites en étoile, données hébergées dans le cloud sans VPN — état actuel confirmé) et sur le laboratoire EVE-NG qui en est le modèle logique :

Phase du cycle	Illustration dans le laboratoire (EVE-NG)
1. Identification	Phase 0 + Lab 2 : inventaire et scans Nmap + OpenVAS (non auth. puis authentifiés) sur le parc mixte — IOS, Windows 10/7, serveur cloud, téléphones IP, caméras.
2. Évaluation	Tableau de risques CVSS + contexte : Win7 EOL (WIN-VULN-01, MS17-010) = priorité Critique, Win10 non patché = routine ; constat F-01 (cloud accessible sans VPN) = Haute/Critique.
3. Remédiation	Lab 1 (durcissement IOS), Lab 2 (migration des postes EOL, SMBv1 off, mots de passe), Lab 4 (tunnel IPSec = mesure compensatoire du F-01).

4. Vérification	Re-scans après chaque lab + Lab 5 (scans planifiés, exports PDF, KPI MTTM / couverture).

Cet alignement démontrera au lecteur du mémoire que le VMS n'est pas un simple « scanneur » : c'est un **processus de pilotage du risque** sur l'infrastructure réelle de l'entreprise.

3. Objectif 2 — Comparaison des scanners de vulnérabilités

3.1 Contexte et critères

La semaine 2 (Objectif 3) exigera de déployer le scanner retenu dans l'environnement de test. Le choix doit donc être **motivé dès maintenant**. Trois candidats, retenus dans le chronogramme : un scanner **opensource** (OpenVAS) et deux **commerciaux** (Nessus, Qualys).

Critères de comparaison : licence et coût · mode de déploiement (on-premises / SaaS) · couverture des contrôles (NVT / plugins) · scans authentifiés · plateformes supportées (Windows, Linux, Cisco IOS, cloud) · rapports et exports · priorisation (CVSS, contexte) · automatisation (API, planification) · **adéquation à un laboratoire isolé** (EVE-NG).

3.2 Profils des trois scanners

- **OpenVAS (Greenbone) —** Scanner historique open-source (GPL) ; aujourd'hui au cœur du cadre **GVM** (Greenbone Vulnerability Management) : moteur de scan + gestionnaire + interface web GSA, distribué gratuitement en **Greenbone Community Edition (GCE)** (OVA, Docker, paquets). ≈ 100 000+ NVTs (checks CVE et de configuration) mis à jour quotidiennement ; scans authentifiés (Windows WinRM/SMB, Linux SSH, Cisco SNMP/SSH) ; exports PDF/HTML/XML ; API GVM et planification. Limites de la GCE : pas de support commercial, certaines fonctions avancées réservées à l'édition payante (AVA).
- **Nessus (Tenable) —** Scanner commercial de référence (Tenable). Version gratuite **Nessus Essentials** : limitée à **16 adresses IP** et à un usage personnel. Version Professionnelle : licence payante (abonnement annuel, tarifié au nombre d'IP), plus de 180 000 plugins, interface reconnue, politiques de conformité (CIS, etc.) et plateforme cloud Tenable.io.
- **Qualys (VMDR) —** Solution **100 % SaaS** (cloud-only, aucun déploiement onpremises). Positionnée sur la gestion continue du risque (scans + agents + exposition des assets), avec un excellent management des actifs et des politiques de remédiation ; abonnement payant au nombre d'IP et connectivité permanente requise vers le cloud Qualys.

3.3 Tableau comparatif

Critère	OpenVAS (GCE)	Nessus (Tenable)	Qualys (VMDR)
Licence / coût	Open-source (GPL) — **gratuit**	Essentials gratuit limité à 16 IP ; Pro payant (abonnement)	Commercial SaaS, payant (par IP)
Déploiement	Auto-hébergé : OVA, Docker, paquets	On-premises ou cloud (Tenable.io)	SaaS uniquement (cloud Qualys)
Couverture des contrôles	≈ 100 000+ NVTs, mises à jour quotidiennes	≈ 180 000+ plugins	Large base de contrôles + intelligence de l'exposition

Scans authentifiés	Oui — WinRM/SMB, SSH, SNMP, Cisco	Oui — WinRM/SMB, SSH, SNMP, CIS	Oui + agents
Plateformes couvertes	Windows, Linux, réseaux (IOS), cloud, IoT	Windows, Linux, réseaux, cloud	Windows, Linux, cloud (AWS/Azure), IoT
Rapports / exports	PDF, HTML, XML	PDF, HTML, API	Tableaux de bord, rapports, API
Priorisation	CVSS + criticité d'actif	CVSS + vues de risque	Risk Score (contexte avancé)
Automatisation	API GVM, scans planifiés	API, intégrations Tenable.io	API, flux SaaS
Adéquation au lab (EVENG, 15 nœuds)	**Oui — GBSV sur VM linux, segment management dédié (VLAN 10)**	**Non — Essentials : 16 IP, usage personnel** (Pro payant)	**Non — SaaS, payant, non déployable hors cloud**

3.4 Choix retenu : OpenVAS (Greenbone Community Edition)

Le scanner retenu pour la suite du projet est **OpenVAS**, déployé sous sa forme communautaire gratuite (GCE). Justification :

- **100 % gratuit :** aucun budget, aucune licence à déclarer — indispensable pour un mémoire ;
- **Auto-hébergé :** OVA déployée en VM sur la machine hôte (16 GB), raccordée au lab EVE-NG via un **segment management dédié (VLAN 10, 172.16.10.0/24)** : le scanner occupe sa place naturelle (segment du datacenter) ; le placement sur l'hôte est une contrainte de dimensionnement documentée (EVE-NG plafonné à 8 GB), sans changement de topologie logique ; la démonstration reste reproductible lors de la soutenance ;

- **Couverture adéquate :** ≈ 100 000 NVTs couvrant les CVE et les failles de configuration, y compris Windows (WinRM/SMB) et **Cisco IOS** (SNMP/SSH) — le profil exact du parc université ;
- **Scans authentifiés :** indispensables aux phases 1-2 de la méthodologie (correctifs installés, comptes, configuration) ;
- **Automatisation :** planification, API GVM, exports PDF/XML — supportent directement les objectifs 5 (workflow), 6 (tableau de bord KPI) et 7 (nonrégression) ;
- **Open-source :** code analysable et scripts reproductibles, communauté active, pas de verrouillage fournisseur.

Écarts des autres candidats : **Nessus** — la version gratuite (Essentials) est limitée à **16 IP et à un usage personnel** : le lab (~15 adresses à scanner en baseline, ~18 avec options) y tenait à peine, mais le projet se prolonge sur l'inventaire réel (8 sites, plusieurs dizaines d'adresses) où la limite devient rapidement insuffisante et la version Pro est payante. **Qualys** — SaaS : impossible à déployer dans un lab isolé et abonnement payant.

4. Avancement par rapport au chronogramme

Semaine	Objectif	Livrable attendu	Statut

1	**Obj. 1 :** Cycle de vie de la GdV ; **Obj. 2 :** Comparaison des scanners	Note de synthèse + tableau comparatif	**FAIT (ce document)**
2	**Obj. 3 :** Déploiement du scanner sur l'environnement de test	Environnement opérationnel + rapport du 1er scan	**À venir**
3	**Obj. 4 :** Scoring et priorisation (CVSS + contexte métier)	Grille de scoring + liste priorisée	**À venir**
4	**Obj. 5 :** Automatisation du workflow de remédiation	Workflow automatisé et testé	**À venir**
5	**Obj. 6 :** Tableau de bord de suivi (KPI)	Tableau de bord fonctionnel	**À venir**
6	**Obj. 7 :** Évaluation de l'efficacité de la solution	Rapport d'évaluation final + mémoire	**À venir**

5. Points de vigilance pour l'encadrement

- **Confirmation du choix OpenVAS (GCE)** pour le déploiement de la semaine 2 (OVA sur l'hôte, segment management VLAN 10 du lab EVE-NG).
- **Périmètre de la phase d'identification** : accès à l'infrastructure réelle pour l'inventaire des actifs ou appui sur l'étude de terrain déjà conduite (DC Rectorat, double liaison FO, 8 bâtiments).
- **Délais** : l'environnement de test est déjà conçu en amont (architecture, configurations des équipements, préparation des VM), afin de réduire la durée de la semaine 2.

6. Références

- *FIRST — Common Vulnerability Scoring System (CVSS) v3.1, specification.*
- *NIST SP 800-40 r5 — Guide to Enterprise Patch Management Technologies.*
- *NIST SP 800-53 — Security and Privacy Controls (RA-5 : Vulnerability Scanning, Monitoring, and Testing).*
- *ISO/IEC 27001:2022 — Annexe A, contrôle A.8.8 (Gestion des faiblesses et vulnérabilités techniques).*
- *CIS Controls v8 — 8.5 Software Vulnerability Management.*
- *PCI DSS v4.0 — exigences 11.3 / 11.4 (gestion des vulnérabilités, scans techniques).*
- *Greenbone — documentation GVM / OpenVAS (greenbone.net, dépôt GitHub greenbone/gvm).*
- *Tenable — documentation Nessus (tenable.com).*
- *Qualys — documentation VMDR (qualys.com).*